A Study on

Multi-Party Consent Management System

A thesis submitted in fulfilment of the requirements for the degree of

Doctor of Philosophy

in

Computer Science

by

Yasir Dhaifallah O Alyoubi

Supervisor: Professor Farookh Hussain

Co-supervisor: Dr Firas Al-Doghman

School of Computer Science

Faculty of Engineering and Information Technology

University of Technology Sydney

NSW, Australia

July 2027

CERTIFICATE OF ORIGINAL AUTHORSHIP

I, Yasir Dhaifallah O Alyoubi, declare that this thesis, submitted in fulfilment of the requirements for the award of Doctor of Philosophy, in the School of Computer Science, Faculty of Engineering and Information Technology at the University of Technology Sydney, Australia, is wholly my own work unless otherwise referenced or acknowledged. In addition, I certify that all information sources and literature used are indicated in the thesis. This document has not been submitted for qualifications at any other academic institution. This research is supported by the Australian Government Research Training Program.

Signature of Candidate: Yasir Dhaifallah O Alyoubi

Date:

DEDICATION

To my family

ACKNOWLEDGMENTS

All praise is due to Allah, Lord of the worlds, who gave me the strength, the patience and the means to reach this point. Every step of this journey was by His grace, and I thank Him first and last.

A thesis is never the work of one person, and when it is finished it is right to look back and thank those who made it possible. My deepest gratitude goes to my supervisor, Professor Farookh Hussain. He accepted me as his student, guided my research from its first idea to its last chapter, corrected me with patience when I was wrong, and encouraged me when I doubted myself. He was more than a supervisor to me; he was a mentor and an elder brother, and his door was always open. Without his support I could not have completed this work.

I also thank my co-supervisor, Dr Firas Al-Doghman, for his guidance, his careful reading of my work and his advice at every stage of this research.

I thank the University of Technology Sydney for giving me the opportunity to study here, for the scholarship that made this research possible, and for the environment, the resources and the people that made it a second home.

Finally, I thank my family. My parents, whose prayers and sacrifices have been with me all my life. My wife, who stood beside me through every long day and night of this journey and carried more than her share so that I could study. My children, who gave me the reason to keep going. And my brothers and sisters, whose support never failed. This thesis is for all of them.

PUBLICATIONS

Conference publications

1- 'A Blockchain-Based Framework for Evaluating User Identity Trustworthiness in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

2- 'Blockchain-Based Reputation Borrowing Model to Address the Cold Start Problem for New Users in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

3- 'A Smart Contract-Governed Lifecycle Protocol for Reputation Borrowing in Blockchain-Based Real Estate Platforms', ICEBE 2026. (Accepted)

4- 'A Trusted Multi-Party Consent Governance Framework for Decentralized Multi-Stakeholder Data Sharing', BWCCA 2026. (Accepted)

5- 'Blockchain-Based Reputation Provenance Tracing for Newcomer Bootstrapping in Real Estate', BWCCA 2026. (Accepted)

TABLE OF CONTENTS

Certificate of Original Authorship ..... **i**

Dedication ..... **ii**

Acknowledgments ..... **iii**

Publications ..... **iv**

Table of Contents ..... **v**

List of Figures ..... **viii**

List of Tables ..... **ix**

Abstract ..... **x**

1 Introduction **1**

1.1 Introduction 1
1.2 Statement of the Problem 1
1.3 Research Motivation 2
1.4 Decentralised Identity Technology 3
1.4.1 Decentralised Identifiers (DIDs) 4
1.4.2 Verifiable Credentials (VCs) 4
1.4.3 Trusted Issuers and Credential Verification 4
1.5 Multi-Party Authorisation 4
1.6 The Relationship between Multi-Party Authorisation and Patient Consent 5
1.7 Purpose of Using Multi-Party Authorisation in Consent Management 5
1.8 Authorisation Evidence and Auditability 5
1.8.1 The Audit Ledger 5
1.9 Consent Management Systems 6
1.10 Challenges Faced by Current Consent Management Systems 6
1.11 Research Contribution 6
1.11.1 Scientific Contribution 6
1.11.2 Social Contribution 7
1.12 Thesis Plan 7
1.13 Conclusion 7

2 A Systematic Literature Review **9**

2.1 Introduction 9
2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation 9
2.2.1 Req 1: Representation of consent as an evaluable authorisation object. 10
2.2.2 Req 2: Decentralised verification of identity and authority 10
2.2.3 Req 3: Multi-party authorisation through a verifiable threshold 10
2.2.4 Req 4: Policy- and context-aware enforcement at the time of access. 10
2.2.5 Req 5: Temporal validity and lifecycle control of consent 10
2.2.6 Req 6: Verifiable auditability and security assurance 10
2.3 Process Adopted for Shortlisting the Papers for SLR 11

2.3.1 Step 1: Criteria for Searching the Literature....11
2.3.2 Step 2: Inclusion and Exclusion Criteria....12
2.3.3 Step 3: Quality Evaluation....13
2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas....14
2.4 Summary of Papers Shortlisted in the SLR....15
2.4.1 Consent representation and blockchain-based consent governance (Req 1)....15
2.4.2 Decentralised identity and authority trust (Req 2)....16
2.4.3 Multi-party authorisation and collaborative consent (Req 3)....16
2.4.4 Policy- and context-aware access control (Req 4)....18
2.4.5 Temporal validity and consent lifecycle (Req 5)....19
2.4.6 Formal security assurance and empirical validation (Req 6)....19
2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective....20
2.5 Trust-Oriented Multi-Party Consent Authorisation Framework....24
2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)....25
2.5.2 Decentralised Verification of Identity and Authority (Req 2)....25
2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)....25
2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4) 25
2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)....25
2.5.6 Verifiable Auditability and Security Assurance (Req 6)....25
2.6 Conclusion....25

3 Research Questions and Objectives....27

3.1 Introduction....27
3.2 Gaps in the Literature....27
3.3 Key Definitions....27
3.4 Research Questions....28
3.4.1 Research Questions as an Integrated Problem....29
3.5 Research Objectives....29
3.5.1 RO1: Trust-Centric Consent Model....29
3.5.2 RO2: Decentralised Identity and Authority Trust....30
3.5.3 RO3: Trustworthy Multi-Party Authorisation....30
3.5.4 RO4: Policy- and Context-Aware Access Control....30
3.5.5 RO5: Temporal and Lifecycle Trust....30
3.5.6 RO6: Formal Security Assurance and Empirical Validation....31
3.5.7 Relationship Between Research Questions and Objectives....31
3.6 Conclusion....32

4 Research Methodology and Solution Overview....33

4.1 Introduction....33
4.2 Key Definitions....33
4.3 Selected Research Methodology....34
4.4 Solution Overview....34
4.5 Overview of Solution for RQ1....36
4.6 Overview of Solution for RQ2....37

4.7 Overview of Solution for RQ3.....37
4.8 Overview of Solution for RQ4.....37
4.9 Overview of Solution for RQ5.....37
4.10 Overview of Solution for RQ6.....38
4.10.1 Testing and Verification of the Solution.....38
4.11 Conclusion.....38

LIST OF FIGURES

2.1 PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages..... 13
2.2 Synthesis of the review: the conjunction gap and the assurance gap addressed by the proposed framework, with the number of the 25 analysed studies graded Yes for each requirement in Table 2.10.....23
4.1 The Design Science Research process of this thesis, with the output of each stage, adapted from Peffers et al. (2007).....34
4.2 End-to-end workflow of the trust-oriented consent authorisation framework. 35

LIST OF TABLES

2.1 Databases searched and records retrieved.....11
2.2 Summary of the stages of evaluating and selecting the relevant papers for the SLR.....12
2.3 Listing of the 25 primary studies identified after the selection process.....14
2.4 Descriptions, issues and limitations of the studies on consent representation..15
2.5 Descriptions, issues and limitations of the studies on identity and authority…16
2.6 Descriptions, issues and limitations of the studies on multi-party authorisation 17
2.7 Descriptions, issues and limitations of the studies on policy and context.....18
2.8 Descriptions, issues and limitations of the studies on temporal validity and lifecycle.....19
2.9 Descriptions, issues and limitations of the studies on security assurance.....20
2.10 Comparison of the included studies against the key requirements.....22
3.1 Research questions, research objectives, and the status of each objective.....32

ABSTRACT

Patient consent is the permission a patient gives for their health data to be used or shared. In most healthcare systems, consent is stored as a record and is checked once, when the permission is first given. After that, access to the data depends on the login of the person asking and on a stored permission in the hospital system. This arrangement does not show whether the person asking is really who they claim to be, whether they have the authority to ask, whether the people who had to agree have all agreed, or whether the consent is still in force at the time of the request.

The problem is harder when the patient cannot decide alone. A child, an elderly patient or a patient without capacity depends on guardians, and in these cases more than one person must agree before the data can be released. Decentralised identifiers (DIDs) and verifiable credentials (VCs) can establish who a participant is and what role they hold, and blockchain can keep a tamper-resistant record of what was agreed. Previous researchers have already proposed each of these technologies for healthcare data sharing. However, through a systematic literature review of 25 primary studies, we have identified that the existing literature treats identity, authority, multi-party approval, purpose, time and the state of the consent as separate conditions. No reviewed study joins them in one decision that is evaluated at every access request, and none proves or tests the decision as a whole.

The primary objective of this study is to propose and develop a trust-oriented authorisation framework termed HALAH, in which patient consent is no longer a stored record but an object that can be evaluated. The consent object carries the identity of the participants, the authority requirements, the guardians named by the patient, the purpose and data scope, the validity period, the lifecycle state and the evidence of every decision. Access is allowed only when the identity check, the approval check, the policy check, the time check and the lifecycle check all pass together, and any failed check gives a refusal that is recorded.

The mechanisms built into HALAH provide the following: (i) a consent model in which consent is represented as an evaluable authorisation object; (ii) verification of the identity and the authority of every participant through DIDs and VCs, so that a valid identity alone does not grant access; (iii) a multi-party authorisation rule in which only verified and distinct approvals from the guardians named by the patient count, and no single party can activate the consent alone; (iv) enforcement of purpose, data scope, validity period and lifecycle state at the time of each request; and (v) an audit ledger that records every decision with the result of each check. Finally, in order to validate the correctness and the security of the proposed framework, software prototyping is chosen as the validation method. The prototype is tested with synthetic patient records, with automated tests, and with attack scenarios in which each check is deliberately bypassed.

CHAPTER 1

INTRODUCTION

1.1 Introduction

Secure and trustworthy data sharing is now needed across organisational boundaries. Modern digital ecosystems involve multiple independent stakeholders, including individuals, healthcare providers, regulatory authorities, researchers, and third-party data processors (Ghafoor et al. 2025; Lomotey, Kumi & Deters 2022; Nguyen et al. 2025). Digital services make collaboration easier, but they also raise a governance question: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain? Healthcare is a clear example of this problem. The increasing digitisation of healthcare information enables patients, healthcare professionals, guardians, researchers, and healthcare organisations to participate in data-sharing processes (Webber et al. 2019; Welzel et al. 2025). At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control.

Traditional access-control architectures are based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms. These approaches can provide effective access control within an organisational boundary, but they become difficult to apply when authorisation decisions involve multiple independent entities. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain. This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, and institutional authorities (Ibrahim et al. 2024; Webber et al. 2019). In these settings, authorisation is a distributed governance problem, not just a check of a user's login and a static permission (Theodorakopoulos, Theodoropoulou & Halkiopoulos 2024).

Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability (Al Mamun, Azam & Gritti 2022; Hellstern et al. 2022; Li, Liu & Shrestha 2026; Nguyen et al. 2025), while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles or authority, and policy-based access-control mechanisms can restrict access to authorised resources. However, an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, or that a subsequent data-access request remains consistent with the conditions originally authorised. Consent must therefore be treated as an active, evaluable part of the authorisation process, not as a static record of permission, extending the dynamic consent perspective (Khalid et al. 2023; Narkhede, Wankhede & Kamble 2025).

1.2 Statement of the Problem

Existing consent-management and decentralised access-control approaches represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created (Jesus & Pandit 2022; Khalid et al. 2023). The relationship between the consent record, the identity of the participants, their authority to act, the applicable policy constraints, and the resulting access decision is frequently treated as separate technical concerns. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information. Even where identity and collective approval have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects identity, authority, multi-party approval, policy, temporal, and lifecycle conditions within a coherent authorisation decision and whose security can be formally and empirically demonstrated. Existing approaches provide important technological components, including decentralised identity and verifiable credentials (Phuyal et al. 2026b; Wu & Zhang 2025), blockchain-based records, multi-party approval mechanisms (Ekholm et al. 2025; Punia et al. 2025; Tan, Chi & Lam 2024), and policy-based access control (Eneh et al. 2026; Khayer et al. 2025; Panagoulias et al. 2026; Román-Martínez et al. 2023), as well as several partial combinations. However, these mechanisms are often investigated independently or integrated primarily at the implementation level. The overarching research question is how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints. The research objectives are operationalised through six corresponding sub-research questions (SRQ1 to SRQ6, referred to as RQ1 to RQ6).

1.3 Research Motivation

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied. Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments (Li et al. 2026b; Ménétrey et al. 2022). Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed. Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems. Future work can therefore investigate how trusted execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.

Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role or permission to participate in a particular decision. Multi-party authorisation concerns whether the required set of independently verified participants has satisfied a defined collective approval condition. Policy compliance concerns whether the requested access is consistent with the authorised purpose and data scope. Time and lifecycle concern whether the consent is still within its validity window and has not expired or been revoked. Together, these

conditions decide whether an authorisation decision has enough basis to be trusted, not only whether access was requested. The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object, C = (I, A, P, T, L, E), that connects the relevant participants, authority requirements, policy constraints, temporal and lifecycle conditions, and evidence associated with an authorisation decision. In C, I is identity and A is authorisation, which holds the guardian set G and the threshold N. P is policy, which covers purpose and data scope. T is time, L is the lifecycle state of the consent, and E is evidence.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient. These four dimensions, RO1 to RO4, collectively define the foundational scope of Multi-Party Patient Consent. RO1 to RO4 are completed with validation and evaluation at the current stage. RO5 adds temporal validity and lifecycle trust, because trust cannot be regarded as permanently established at the moment a consent is created. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state. RO6 concerns formal security assurance and empirical validation. RO5 is in progress, and part of it has already been delivered. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH (History Access Link for Authorised Healthcare) prototype. For RO5, this prototype provides a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation. The remaining formal security assurance and comprehensive empirical evaluation will be conducted in the next stage.

HALAH runs on the Ethereum Sepolia testnet, and the guardian approval rule is currently implemented as N-of-N over the guardian set G. Synthetic healthcare records derived from the Synthea dataset are used to construct representative consent workflows. Security properties are demonstrated through adversarial and negative testing, as well as empirical evaluation using the HALAH prototype and representative healthcare data-sharing scenarios, rather than formal proof. The current stage covers the work delivered so far, while temporal and lifecycle trust, formal security assurance, and comprehensive empirical validation will be developed further in the next stage.

1.4 Decentralised Identity Technology

The framework proposed in this thesis is built on three technologies: decentralised identity, multi-party authorisation and auditable authorisation evidence. This section and the two that follow introduce each of them in turn. Decentralised identity is the first. In a conventional healthcare system, the identity of a doctor, a patient or a guardian is held by one organisation, usually the hospital, and is checked by a login to that organisation. A participant from another organisation cannot be verified without an agreement between the two organisations, and the organisation that holds the account can change or remove it at any time. Decentralised identity moves the identifier and the proof of identity to the participant (Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023). The participant holds an identifier that is not issued by the data holder, and the data holder verifies claims about that participant rather than

looking them up in its own directory. In healthcare, this allows a doctor from one hospital, a guardian who is not a patient of any hospital, and a patient to take part in one consent decision without sharing one identity provider (Shanmugham & Senthilkumar 2026; Wu & Zhang 2025).

1.4.1 Decentralised Identifiers (DIDs)

A decentralised identifier (DID) is a string of the form did:method:identifier that names one participant. The method part states how the identifier is resolved and the last part is unique within that method. A DID is controlled by the holder through a cryptographic key, so the holder can prove control of the identifier by signing with that key, and nobody else can speak for it (Mazzocca et al. 2025). A DID on its own says nothing about the role of its holder. It only states that there is one participant and that this participant can sign. In this thesis, every participant has a DID: the patient, each guardian, the doctor and the issuer of credentials. Full resolution of a DID to its public keys, and the proof that a user controls the DID they present, are treated as work for the next stage (Deng et al. 2024; Yin et al. 2025).

1.4.2 Verifiable Credentials (VCs)

A verifiable credential (VC) is a signed statement, issued by one party about another, that can be checked by a third party without going back to the issuer (Flamini et al. 2024; Mazzocca et al. 2025). A credential names the subject by its DID, states one or more claims, such as the role of doctor or guardian and the organisation, carries a validity period, and is signed by the issuer. The credential is what separates identity from authority: the DID shows who the participant is, and the VC shows what the participant may do. This separation is central to the framework, because a valid identity must never be enough on its own to reach patient data.

1.4.3 Trusted Issuers and Credential Verification

A credential is only as good as its issuer. The framework therefore keeps a registry of trusted issuers, such as a health authority, and a credential is accepted only when its signature recovers to the registered key of an issuer in that registry. Four conditions are checked on every credential: the signature is valid, the issuer is trusted, the subject of the credential is the DID that presented it, and the current time lies within the validity period. A credential also has to carry the role that the step requires, so a guardian credential cannot be used to act as a doctor. In the prototype, one demonstration issuer signs all credentials, and the credential check demonstrates the verification rather than the secrecy of the issuer key.

1.5 Multi-Party Authorisation

Multi-party authorisation is a rule under which a decision needs the agreement of more than one party before it takes effect. In healthcare consent, the parties are the people who must agree before a patient's data can be released: the patient, and for a minor or an incapacitated patient, the guardians (Hagström et al. 2024; Webber et al. 2019). The reviewed literature contains several forms of multi-party approval. Madine et al. (2020) require a regulator and a guardian threshold when the patient is incapacitated, Wu et al. (2022) use a threshold of investigators to admit and revoke records, Zhao and Su (2024) delegate authority through a threshold, Tan, Chi and Lam (2024) let the patient appoint verifiers, and Maruthi and Singh (2025) treat the guardians of an unconscious patient as the approving parties.

In this thesis, multi-party authorisation is defined by two elements that the patient sets when the consent is created: the guardian set G, which lists the participants whose

approval is required, and the threshold N, which is the number of valid approvals needed. An approval counts only when it comes from a member of G, when it is signed by that member, and when that member has not already approved the same consent. An approval from a signer outside G, or a second approval from the same guardian, does not advance the count. In the current prototype, every listed guardian must approve, so N equals the size of G, and the rule has been demonstrated with two guardians.

1.6 The Relationship between Multi-Party Authorisation and Patient Consent

Patient consent and multi-party authorisation are often handled by different parts of a system. The consent is a record of what the patient allowed, and the approval of the guardians is a separate step that happens once, for example at registration (Ekholm et al. 2025) or when a patient is admitted (Wu et al. 2022). Once that step has passed, later requests for data do not look at it again. In this thesis, the two are joined. The guardian set and the threshold are part of the consent object itself, and the approvals that the guardians give are stored with the consent as evidence. A consent with fewer approvals than its threshold stays pending and cannot release any data. A consent that reached its threshold becomes active, and the approvals are checked again whenever a doctor asks for data, together with the identity, policy, time and lifecycle conditions. Multi-party authorisation is therefore not a gate that the consent passes once, but a standing condition that the consent must keep satisfying for as long as it is used.

1.7 Purpose of Using Multi-Party Authorisation in Consent Management

There are three reasons for placing multi-party authorisation inside consent management rather than beside it. The first is that it removes the single point of decision. Where a patient cannot decide alone, no one guardian, and no hospital account, should be able to release the data on their own. The second is that it keeps the approving set under the control of the patient. In the reviewed studies, the parties who must approve are usually chosen by the institution or by a delegate (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024). In the proposed framework, the patient names them when the consent is created, and the system enforces that list. The third is that it makes the approval verifiable after the event. Each approval is a signature over the consent identifier and the guardian identifier, so an auditor can later confirm who approved which consent, and a signature cannot be moved from one consent to another.

1.8 Authorisation Evidence and Auditability

A decision to release patient data must be explainable afterwards. It is not enough to record that access happened; the record must show why it was allowed or refused. The framework treats this as the evidence component E of the consent object. For every request, the result of each check is written down together with the decision, so that a later reader can see whether the requester was verified, whether the approvals were sufficient, whether the purpose and scope were within the consent, whether the consent was in its validity period, and whether its lifecycle state allowed access. Blockchain or other tamper-resistant storage can be used to preserve selected evidence (Andrew et al. 2023; Li, Liu & Shrestha 2026), but in this thesis the blockchain is not the source of trust. Trust comes from the checks themselves; the storage only makes their record harder to alter.

1.8.1 The Audit Ledger

In the prototype, the evidence is kept in an audit ledger. The ledger is an append-only list of events. Each event records the actor, the action, the consent identifier, the time, the result and, for an access decision, the outcome of the five checks. A digest of the key fields of each event is computed and stored with it, so that any later change to a stored event can be detected. The ledger records the creation of a consent, each guardian approval, each state check, each data access and each revocation. Refusals are recorded as well as grants. The auditor interface reads this ledger and presents the decisions in the order in which they were made.

1.9 Consent Management Systems

A consent management system records what a patient has allowed and makes that record available to the systems that hold the data. The simplest systems store a signed form. Dynamic consent systems let the patient change the permission over time and notify the parties affected (Albalwy, Brass & Davies 2021; Khalid et al. 2023). Purpose-based systems tie the permission to a stated purpose, such as treatment or research (Tith et al. 2020), and consent receipts give the patient a readable record of each permission (Jesus & Pandit 2022). More recent systems place the consent on a blockchain so that it cannot be altered quietly, and some of them connect it to an access-control layer (Jaiman & Urovi 2020; Phuyal et al. 2026a; Zhang, Kan & Huang 2022). All of these systems have one thing in common: the consent is treated as a record of a permission. The access decision that follows is made by another component, usually an access-control list or a role check, and that component looks at the consent record only to confirm that it exists.

1.10 Challenges Faced by Current Consent Management Systems

The systematic literature review in Chapter 2 identifies six challenges in the current generation of consent management systems. They are summarised here and stated in full in Chapter 3.

First, consent is represented as a record of permission rather than as an object that can be evaluated, and the few evaluable consent objects carry only some of the conditions that an access decision needs. Second, a valid decentralised identity establishes who a participant is but not what the participant is authorised to do, and authority is checked separately from authentication in only a minority of the reviewed studies. Third, multi-party approval appears as a contingency path, an admission gate or a registration-time co-consent, but not as a standing condition of every access decision with an approving set defined by the patient. Fourth, purpose and data-scope constraints are rarely bound to the same decision as identity, authority and multi-party approval. Fifth, validity periods, lifecycle state and revocation are often enforced on a credential or at registration rather than at the time of each request. Sixth, the authorisation decision as a whole is neither formally proved nor systematically tested.

The first five challenges together mean that the conditions for a trustworthy decision exist but are never joined. The sixth means that, even where they are joined, nobody has shown that the joined decision behaves as intended. This thesis addresses both.

1.11 Research Contribution

1.11.1 Scientific Contribution

The scientific contributions of this research are threefold. First, this research proposes a trust-centric consent model that integrates identity, authority, multi-party approval, and policy constraints into a unified healthcare authorisation framework. Second, this research proposes a multi-party authorisation mechanism that requires approval from

multiple verified participants before granting healthcare data access, where collective consent is required. Third, this research proposes a trust-aware authorisation approach that evaluates identity, authority, collective approval, and policy compliance when determining healthcare data-access permissions.

1.11.2 Social Contribution

The social contributions of this research are also threefold. First, this research aims to help patients and their guardians manage consent for sharing sensitive healthcare information, supporting greater control over healthcare data access. Second, this research aims to support patient privacy by restricting healthcare data access according to authorised purposes and data scopes. Third, this research aims to support transparency and accountability in healthcare data sharing by providing verifiable records of consent activities and access decisions.

1.12 Thesis Plan

This thesis is organised into eleven chapters.

Chapter 1 introduces the research. It states the problem, gives the motivation, introduces the three technologies on which the framework is built, summarises the challenges in current consent management systems, and lists the contributions of the thesis.

Chapter 2 presents the systematic literature review. It defines the six key requirements for trustworthy multi-party consent authorisation, describes the process used to search, select and assess the literature, reviews the 25 primary studies in six streams, compares them against the requirements, and identifies the research gap.

Chapter 3 states the research gap, the main research question, the six sub-research questions and the six research objectives, and shows how they form one integrated problem.

Chapter 4 presents the research methodology, which is design science research, and gives an overview of the proposed solution for each research question.

Chapter 5 presents the research architecture, based on the model-view-controller pattern, and the trust-centric consent model of Research Objective 1, in which consent is represented as the evaluable object $C = (I, A, P, T, L, E)$.

Chapter 6 presents the decentralised identity and authority verification mechanism of Research Objective 2.

Chapter 7 presents the multi-party authorisation mechanism of Research Objective 3.

Chapter 8 presents the policy- and context-aware access control mechanism of Research Objective 4.

Chapter 9 presents the temporal validity and consent lifecycle controls of Research Objective 5.

Chapter 10 presents the formal security assurance and the empirical validation of Research Objective 6, together with the working of the HALAH prototype, the dataset used, the live scenarios, the measured results and the attack scenarios.

Chapter 11 concludes the thesis and sets out the directions for future work.

1.13 Conclusion

This chapter introduced the research. It described the setting in which patient data are shared across organisations, stated the problem that current consent and access-control systems treat consent as a stored record rather than as a condition that is evaluated at

each request, and gave the motivation for a trust-oriented approach in which trust is the outcome of several independently verified conditions. It introduced decentralised identity, multi-party authorisation and auditable authorisation evidence as the three technologies on which the proposed framework is built, summarised the six challenges found in current consent management systems, and listed the scientific and social contributions of the thesis. The next chapter reviews the literature systematically and establishes the gap that this thesis addresses.

CHAPTER 2

A SYSTEMATIC LITERATURE REVIEW

2.1 Introduction

The review does not only list technologies that can be applied to healthcare data sharing. It examines how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing (Kaplow et al. 2024; Kharlamov, Hohmann & Parry 2023; McClelland & Harper 2023; Narkhede, Wankhede & Kamble 2025; Webber et al. 2019). Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management (Andrew et al. 2023; Arbabi et al. 2023; Ghosh et al. 2023; Nguyen et al. 2025; Turan, Hashimzai & Qiam 2025). Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication (Deng et al. 2024; Flamini et al. 2024; Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023; Parameswarath, Gope & Sikdar 2022; Yin et al. 2025). Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information (Jiang et al. 2023; Nazir et al. 2026; Tawfik et al. 2025; Yin et al. 2024). However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. Having the security mechanisms is one thing. Combining them into one trustworthy authorisation decision is another.

The structure of this chapter is as follows. Section 2.2 presents the six key requirements that a trustworthy multi-party consent authorisation should satisfy and that serve as the basis of the comparison. In Section 2.3, the process adopted for shortlisting the papers chosen for this SLR is discussed, including the criteria for searching the literature, the inclusion and exclusion criteria and the quality evaluation. Section 2.4 presents a summary of all the papers that were shortlisted, 25 in all, in six streams, and states the research gaps from the requirement perspective. In Section 2.5, the trust-oriented multi-party consent authorisation framework proposed in this thesis is positioned against the requirements. Finally, Section 2.6 concludes the SLR.

2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation

Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The six requirements below collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation. Each matches one sub-research question (Chapter 3), and each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework.

2.2.1 Req 1: Representation of consent as an evaluable authorisation object

- Rather than representing consent as a simple association between a patient, a requester, and a permission, consent should be represented as a structured and evaluable authorisation object. The object should incorporate identity information, authority requirements, policy constraints on purpose and data scope, temporal validity, lifecycle state, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

2.2.2 Req 2: Decentralised verification of identity and authority

- Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. Participants should establish persistent and cryptographically verifiable identifiers without dependence on a single identity provider. Identity verification establishes who is participating, while authority verification determines whether that entity satisfies the requirements associated with a particular consent. This separation prevents successful authentication from being interpreted as automatic authorisation.

2.2.3 Req 3: Multi-party authorisation through a verifiable threshold

- Multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access. A predefined threshold of independent approvals from designated parties should be modelled as an explicit and independently verifiable security condition within the consent object.

2.2.4 Req 4: Policy- and context-aware enforcement at the time of access

- A requester may possess a valid identity, valid credentials, and even the required multi-party approval while still requesting information outside the scope authorised by the patient. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent. This applies to every request, because many unauthorised disclosures are caused by legitimate requesters who exceed their scope (Jiang et al. 2023).

2.2.5 Req 5: Temporal validity and lifecycle control of consent

- A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. The requirement is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, immediate and verifiable revocation, and unauthorised state transitions are correctly enforced at every request.

2.2.6 Req 6: Verifiable auditability and security assurance

- A system may execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision. Every decision should preserve verifiable evidence to explain the reason for that decision. Formal analysis or systematic adversarial testing should provide a complementary layer through which the expected security properties of the authorisation model can be explicitly defined and examined.

2.3 Process Adopted for Shortlisting the Papers for SLR

This section details the process adopted to identify the relevant papers to be reviewed in the SLR. A four-step process was adopted:

Step 1: Searching the literature. This step involves defining the search terms, identifying the data sources and the process of data collection.

Step 2: Inclusion and exclusion criteria. Criteria are defined to guide the selection of the most relevant studies.

Step 3: Quality evaluation. Each of the full-text studies is reviewed against six quality evaluation questions, one for each key requirement.

Step 4: Data analysis. After reviewing the selected studies, data are extracted, recorded and categorised into streams.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 statement (Page et al. 2021). PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. A written protocol (Protocol v1.1) fixed the review questions, databases, master query, eligibility criteria, codebook, and quality items before screening. All screening, coding, and quality assessment were carried out by the author. This systematic literature review (SLR) is guided by seven review questions. Questions 1 to 5 correspond to Req 1 to Req 5, and Questions 6 and 7 together to Req 6. The questions follow the technical objectives of the proposed system.

2.3.1 Step 1: Criteria for Searching the Literature

This step involved deciding the databases to search, the search string, the information required from each record and the publication period of the records.

The literature search was conducted using the following academic databases including 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) ProQuest Science and Technology, 6) Scopus, and 7) Web of Science. These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies. One master query of three concept blocks joined by AND covered healthcare data, consent and authorisation, and trust and multi-party concepts. The search string was ("Healthcare" OR "Health Data" OR "Medical Records") AND ("Consent" OR "Authorisation" OR "Authorization") AND ("Trust" OR "Multi-party" OR "Multi-party Approval"). The search strings were constructed using Boolean operators and were adapted only to the syntax requirements of each database.

Table 2.1 shows the seven databases and the number of records retrieved from each.

Table 2.1: Databases searched and records retrieved

S/N	Database	Records
1	SpringerLink	46
2	Scopus	38
3	IEEE Xplore	27
4	ProQuest Science and Technology	24
5	Web of Science	19
6	ScienceDirect	14
7	ACM Digital Library	11
	Total	179

2.3.2 Step 2: Inclusion and Exclusion Criteria

Not all the records identified in the previous step are considered in the SLR. They were further shortlisted according to the following inclusion and exclusion criteria.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening. Each study is cited by the year of the journal issue or proceedings volume in which it appeared, not the year it was first published online.

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. Inclusion required healthcare data (IC1), consent, authorisation, access control, trust, or governance relevant to data access (IC2), and a mechanism, model, system, or evaluation relevant to a review question (IC3). Studies also had to be peer-reviewed English papers with full text (IC4 to IC7). The search was restricted to studies published between 2020 and 2026. Nine exclusion criteria (EC1 to EC9) removed, among others, studies outside healthcare or the authorisation scope, studies of authentication alone or with only a superficial mention of consent, non-peer-reviewed work, duplicate publications, and secondary reviews, although no study was excluded for failing to support the proposed research gap. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the review questions rather than by the presence of a single keyword.

Inclusion criteria:

1. Healthcare data sharing (IC1).

2. Consent or authorisation relevant to data access (IC2).

3. A model, mechanism, system or evaluation that addresses a review question (IC3).

4. Peer-reviewed English paper with full text (IC4 to IC7).

5. Publication between 2020 and 2026.

Exclusion criteria:

1. Outside healthcare or the authorisation scope.

2. Authentication alone or a superficial mention of consent.

3. Non-peer-reviewed work and duplicate publications.

The stages of evaluating and selecting the relevant papers for the SLR are summarised in Table 2.2.

Table 2.2: Summary of the stages of evaluating and selecting the relevant papers for the SLR

Evaluation stage	Method	Assessment criteria	Records
1st	Identify the related studies from the seven databases	Match the search string	179 identified
2nd	Remove duplicate records	Same title, author, DOI and publication year	21 removed, 158 remain
3rd	Screen the titles	Within healthcare consent or authorisation; otherwise exclude	76 excluded, 82 remain
4th	Screen the abstracts	Relevant to a review question; otherwise exclude	43 excluded, 39 remain
5th	Assess the full texts	Eligibility criteria and the quality evaluation of Step 3	14 excluded, 25 included

Figure 2.1 presents the PRISMA flow diagram for this review, which summarises the identification, screening, eligibility, and inclusion stages of the SLR. The seven database

searches returned 179 records: 46 from SpringerLink, 38 from Scopus, 27 from IEEE Xplore, 24 from ProQuest, 19 from Web of Science, 14 from ScienceDirect, and 11 from the ACM Digital Library. After 21 duplicates were removed, 158 records were screened by title, and 76 were excluded. The abstracts of the remaining 82 records were screened, and 43 were excluded. The full texts of 39 studies were then assessed for eligibility, 14 were excluded, and 25 studies were included in the analysis.

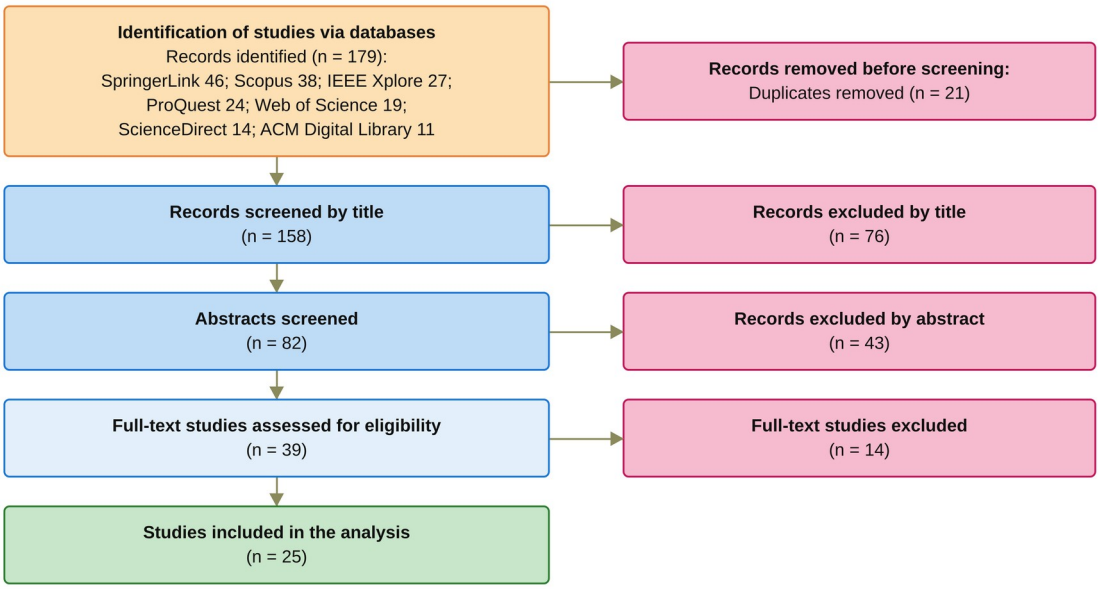


Figure 2.1: PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages.

2.3.3 Step 3: Quality Evaluation

The 39 full-text studies were retrieved and critically evaluated based on the six quality evaluation questions, one for each key requirement of Section 2.2, as follows:

QA1: Does the study define a consent model covering identity, authority, policy, and evidence?

QA2: Does the study verify participant identities and their authorisation authority?

QA3: Does the study support consent decisions requiring approval from multiple authorised participants?

QA4: Does the study enforce purpose, data scope, and approval rules before allowing access?

QA5: Does the study manage consent validity, expiry, and revocation?

QA6: Does the study validate security and access decisions through formal analysis or implementation testing?

Quality inclusion uses QA1 to QA4. Each question was answered Yes or No, and any study which has at least three Yes answers to QA1 to QA4 is included in this SLR. QA5 and QA6 were answered for every included study but were not used for inclusion. Of the 39 full-text studies, 25 satisfied the criteria, as shown in Table 2.3. Each included study was then coded Yes or No against each of the six requirements, Req 1 to Req 6, with a page reference for every Yes. A study is core if its gap-impact verdict is contradicts, weakens or narrows, or if it provides a multi-party approval mechanism. Of the 25 included studies, S1 to S25, 23 are core studies and 2 are supporting studies (Albalwy, Brass & Davies 2021; Li et al. 2026a).

2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas

Each of the shortlisted papers was analysed according to its scope, topic and contribution to the review questions. Based on the analysis, each study was placed in one of six streams, one per requirement: consent representation (Req 1), identity and authority (Req 2), multi-party authorisation (Req 3), policy and context (Req 4), temporal and lifecycle (Req 5) and security assurance (Req 6). Table 2.3 lists the 25 primary studies with their authors, year and title. The papers in each stream are summarised in the next section, and their issues and limitations with respect to the key requirements defined in Section 2.2 are discussed.

Table 2.3: Listing of the 25 primary studies identified after the selection process

Study	Authors and year	Article title
S1	Abbasi et al. (2026)	Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains
S2	Albalwy et al. (2021)	A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study
S3	Al Amin et al. (2023)	Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach
S4	Ekholm et al. (2025)	Implementing electronic informed consent in rare disease genomics
S5	Eneh et al. (2026)	Demo: EdgeConsent: On-Chain Attribute-Based Access Control for Data Consent Management
S6	Hagström et al. (2024)	Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland
S7	Jaiman and Urovi (2020)	A Consent Model for Blockchain-Based Health Data Sharing Platforms
S8	Zhao and Su (2024)	A threshold traceable delegation authorization scheme for data sharing in healthcare
S9	Li et al. (2026a)	Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization
S10	Madine et al. (2020)	Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records
S11	Maruthi and Singh (2025)	Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain
S12	Mei et al. (2026)	Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT
S13	Panagoulias et al. (2026)	Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage
S14	Phuyal et al. (2026b)	Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR↔FHIR Translation
S15	Phuyal et al. (2026a)	A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data
S16	Punia et al. (2025)	An access control system for cloud-based healthcare systems driven by blockchain
S17	Román-Martínez et al. (2023)	Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing
S18	Hema et al. (2026)	Patient Centric Cryptographic Protection of Cloud Electronic Health Records
S19	SooHoo et al. (2026)	Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems

Study	Authors and year	Article title
S20	Tan et al. (2024)	Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification
S21	Tith et al. (2020)	Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology
S22	Tremper et al. (2026)	Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management
S23	Tseng et al. (2025)	EMR-Chain: Decentralized Electronic Medical Record Exchange System
S24	Wu et al. (2022)	Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data
S25	Wu and Zhang (2025)	HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID

2.4 Summary of Papers Shortlisted in the SLR

The extracted data were organised into thematic categories corresponding to the research questions. Each included study was assigned to one stream, normally the one on which it is coded most strongly. S6 (Hagström et al. 2024) is placed in the multi-party stream for its guardian access gate, although it is not graded Yes on Req 3.

2.4.1 Consent representation and blockchain-based consent governance (Req 1)

Two of the three studies of this stream are deployed platforms that do not fully satisfy Req 1. SooHoo et al. (2026) describe the iAgree portal across three United States health systems with a permissioned Ethereum audit contract, but consent enforcement is outside its scope. Tremper et al. (2026) report ten years of the Mainzelliste service with FHIR consent directives, but specify no check semantics and no demonstrated enforcement of withdrawal. The two platforms are single-party systems. Al Amin et al. (2023) model informed consent as a patient-driven policy object with hash integrity, but specify no purpose condition and report no measured results. The supporting references represent consent as a permission indicating whether a particular party is allowed to perform a specified operation (Akter & Sanam 2025; Prashanth et al. 2024), as conditions fixed at encryption time (Zhang, Kan & Huang 2022), or as a key issued by the patient for each request (Teeda & Subba Rao 2026). The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. Table 2.5 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.4: Descriptions, issues and limitations of the studies on consent representation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S3 Al Amin et al. (2023)	Informed consent is modelled as a patient-driven policy object with hash integrity, which an authorisation module conjoins with other policies inside a smart contract.	Purpose is not a condition, the time and expiry conditions are specified but not enforced, the only multi-party element is a 2-of-2 co-signature at registration, and the Goerli evaluation reports no measured results.	Yes	No	No	No	No	No
S19 SooHoo et al. (2026)	The authentication and authorisation processes of the iAgree portal across three United States health systems, using OAuth2, SMART on FHIR, and one-time passwords, with a permissioned Ethereum audit contract.	Consent enforcement is outside its scope, a single patient decides, identity and authority are not separated, revocation is claimed but not tested, and there are no formal methods.	No	No	No	No	No	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S22 Tremper et al. (2026)	Ten years of the Mainzelliste production service for pseudonymisation, record linkage, and informed consent management, with purpose-scoped FHIR consent directives and automated consent checks.	The consent checks have no specified semantics and no demonstrated enforcement of withdrawal, its multi-party computation parties are linkage units rather than authorisers, and no consent decision is verified.	No	No	No	No	No	No

2.4.2 Decentralised identity and authority trust (Req 2)

Req 2, which needs both identity and authority, is graded Yes in only 7 of the 25 studies in Table 2.10. Phuyal et al. (2026b) present the most integrated system, with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs. Its licensing-body credential asserts role and scope of practice separately from authentication, which is among the strongest Req 2 evidence in the corpus. However, a single patient grants consent, the stored expiry is not checked, there is no threat model, and the companion architecture (Phuyal et al. 2026a) is design-only. Tseng et al. (2025) verify authority-issued roles separately from X.509 identities, although without W3C identifiers and with purpose logged but never evaluated. Neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient's information.

Table 2.5 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.5: Descriptions, issues and limitations of the studies on identity and authority

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S14 Phuyal et al. (2026b)	Cross-institution health data sharing with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs, where a licensing-body credential asserts role separately from authentication.	A single patient grants consent, the stored expiry is not checked, purpose is handled only at the interface, and there is no threat model.	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	A design-science architecture for dynamic and auditable patient consent in secondary use, using FHIR Consent with purpose, scope, actors, and validity period, anchored on chain, with conceptual VC validation at a gateway.	The architecture is design-only and is neither implemented nor evaluated, and delegation through VCs is not joint multi-party approval.	No	No	No	No	No	No
S23 Tseng et al. (2025)	EMR-Chain, a decentralised electronic medical record exchange that verifies authority-issued roles separately from X.509 identities and enforces token expiry at the validator.	It has no W3C identifiers, purpose is logged but never evaluated, scope is hospital-level only, the patient and requester signatures authenticate the request rather than add an independent authoriser, and revocation does not invalidate issued tokens.	No	Yes	No	No	No	No

2.4.3 Multi-party authorisation and collaborative consent (Req 3)

Req 3 is graded Yes in 6 of the 25 studies and No in 19, across six mechanism classes. Madine et al. (2020) require a regulator and a guardian threshold on the incapacitated

path, but a single patient key suffices on the normal path. Wu et al. (2022) apply a (t, n) investigator threshold to record admission and revocation, and Abbasi et al. (2026) use a Shamir (5, 3) threshold for key custody. Punia et al. (2025) conjoin an M-of-N multi-signature with an attribute and role policy, but a single emergency officer can bypass the threshold. Tan et al. (2024) use patient-appointed verifiers as a contingency, (Ekholm et al. 2025) reports guardian co-consent at registration time, and (Hagström et al. 2024) gates guardian access by the minor's consent and a clinician's capacity assessment. No reviewed study evaluates a threshold predicate over a patient-designated guardian set on every request, and none does so together with the policy, temporal, and lifecycle conditions. Multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access.

Table 2.6 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.6: Descriptions, issues and limitations of the studies on multi-party authorisation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	Decentralised EHR management in which a Shamir (5, 3) threshold reconstructs a symmetric key, and automated oracles release their shares according to the requester's on-chain role.	The threshold is over key custodians rather than authorisers, the patient share is not required, purpose is not evaluated, and no authorisation decision is verified despite extensive performance measurement.	No	No	No	No	No	No
S4 Ekholm et al. (2025)	A deployed electronic informed consent platform for rare disease genomics, in which a minor's consent is valid only when all legal guardians sign, and guardianship is verified against the Swedish Population Register.	The guardian co-consent applies at registration rather than at each access request, the platform is centralised and described with little technical detail, and there is no temporal, purpose, or formal assurance condition.	No	Yes	Yes	No	No	No
S6 Hagström et al. (2024)	A comparative case study of national patient portals, in which a clinician's capacity assessment and the minor's consent jointly gate guardian access, with register-verified guardianship and enforced age windows.	The mechanism is centralised and applied at documentation time, and the guardian is the party whose proxy access is gated rather than a co-authoriser of the patient's access decision.	No	Yes	No	No	Yes	Yes
S10 Madine et al. (2020)	Fully decentralised multi-party consent management in which, on the incapacitated path, approvals from a regulator and a guardian threshold are required on one access request, and stale attestations stop counting.	On the normal path a single patient key authorises, so multi-party approval is a contingency. Purpose and data-category policy are absent, revocation after delivery is not possible, and there is no formal assurance.	Yes	Yes	Yes	No	Yes	No
S16 Punia et al. (2025)	MedXBlock, a blockchain-driven access control system for cloud healthcare that combines an institutional M-of-N multi-signature with a conjunctive role and attribute policy evaluated with deny-by-default.	The signers are doctors and administrators rather than patient-side parties, the threshold sits outside the decision predicate and a single emergency officer can bypass it, there is no purpose term, and no authorisation decision is verified.	No	No	Yes	Yes	Yes	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S20 Tan et al. (2024)	Sharing of personal health records with multi-party pre-authorisation verification, in which a (t, n) threshold of patient-appointed verifiers each validate the grant, its expiry, and the revocation list before releasing a key share.	The joint approval is a pre-delegated contingency for an unconscious patient rather than a standing condition, purpose and data scope are not evaluated, and the gate is not evaluated empirically as an authorisation decision.	Yes	Yes	Yes	No	No	No
S24 Wu et al. (2022)	Trust computing and privacy-preserving smart contracts for multi-site clinical trial data, in which a (t, n) investigator threshold signature governs trial admission to the ledger and consent revocation.	The consent grant is unilateral, the voters are institution-side investigators, the vote reduces to a hash-integrity check, there is no policy engine, and there is no formal assurance.	No	No	No	No	No	No

2.4.4 Policy- and context-aware access control (Req 4)

Tith et al. (2020) match a purpose tree in chaincode, and Jaiman and Urovi (2020) match ontology terms against the patient's consent. Albalwy et al. (2021) evaluate a hashed policy tree of data type, role, and purpose, and Román-Martínez et al. (2023) evaluate the FHIR purpose-of-use through XACML. Req 4 is graded Yes in 10 studies and No in 15 in Table 2.10. However, purpose-of-use enters the decision in only six studies (Eneh et al. 2026; Panagoulias et al. 2026), and every one is graded No on Req 3. Consequently, purpose and data-scope constraints are not carried by the consent object C and evaluated together with the identity, authority, and multi-party conditions.

Table 2.7 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.7: Descriptions, issues and limitations of the studies on policy and context

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S2 Albalwy et al. (2021)	A blockchain-based dynamic consent proof of concept for clinical genomic data, in which a hashed policy tree of data type, role, and purpose is evaluated by the smart contract.	A single patient sets and cancels consent, the requester's role and credentials are not verified, time is applied only at the delivery layer, and there is no formal assurance.	Yes	No	No	Yes	No	Yes
S7 Jaiman and Urovi (2020)	A consent model in which ontology terms requested by a data requester are matched against the patient's consent inside the smart contract, with denial tested across requester profiles.	Security assurance is explicitly outside its scope, and there is no multi-party approval.	Yes	No	No	Yes	No	Yes
S17 Román-Martínez et al. (2023)	A blockchain-based service-oriented architecture on Hyperledger Fabric for consent management, access control, and auditing, in which FHIR purpose-of-use limits are evaluated per resource through XACML.	There is no withdrawal or expiry path, and the experiments validate only the blockchain component.	Yes	No	No	Yes	No	No
S21 Tith et al. (2020)	A purpose-based consent model on Hyperledger Fabric, in which a consent tuple of role, doctor identifiers, action, and intended purpose is matched against a purpose tree in chaincode at request time.	Consent is given by a single patient, the tuple has no temporal element, the effect of withdrawal is not tested, identity uses Fabric certificates without DID or VC, and there is no formal verification.	Yes	No	No	Yes	No	No

2.4.5 Temporal validity and consent lifecycle (Req 5)

A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Eneh et al. (2026) present EdgeConsent, which enforces temporal validity inside the decision predicate, although its lifecycle is only an active flag. Temporal validity must also be evaluated together with the lifecycle state of the consent. Hema et al. (2026) bind the expiry into key derivation, and Panagoulias et al. (2026) enforce revocation at decision time across 43,500 simulated attempts in a single-node ledger. Req 5 is graded Yes in 8 studies, a post-revocation denial is demonstrated only by (Phuyal et al. 2026b), and the four stream-5 systems that enforce time inside the decision are all single-party, with Li et al. (2026a) doing so through the credential rather than the consent.

Table 2.8 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.8: Descriptions, issues and limitations of the studies on temporal validity and lifecycle

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S5 Eneh et al. (2026)	EdgeConsent, a demonstration of on-chain attribute-based access control in which consent rules with purpose, data category, and notBefore and notAfter bounds are evaluated at decision time.	A two-page demonstration with weak identity and authority trust and no DID or VC, no multi-party approval, a lifecycle that is only an active flag, and preliminary local evaluation without formal assurance.	Yes	No	No	Yes	Yes	No
S9 Li et al. (2026a)	A hybrid RBAC and smart contract scheme with attribute-based authentication for fine-grained EMR access in IoMT, which enforces credential expiry at every sharing interaction.	Time is enforced in the decision through the credential rather than the consent, which is why Req 5 is graded Yes, but the consent itself carries no enforced validity window, and there is no multi-party approval.	No	No	No	Yes	Yes	No
S13 Panagoulias et al. (2026)	Blockchain-enabled trust and compliance for clinical AI, in which an Allow predicate over time, revocation, role, and purpose is evaluated before execution and denials are recorded, verified across simulated attempts with zero consent drift.	A simulated single-node prototype with set-membership policy and aggregate deny attribution, without multi-party approval or identity depth, and the authors declare no formal assurance.	Yes	No	No	Yes	Yes	Yes
S18 Hema et al. (2026)	Patient-centric cryptographic protection of cloud EHRs, in which a signed consent token, role, and expiry are inputs to key derivation, so that access becomes a cryptographic precondition and role-scoped keys separate authority from identity.	Consent is issued from a single patient key, identity relies on a cloud authentication service without DID or VC, and assurance is limited to an adversary model.	Yes	No	No	Yes	Yes	No

2.4.6 Formal security assurance and empirical validation (Req 6)

Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable. Wu and Zhang (2025) present HealthDID, with three game-based definitions and three theorems proved by reduction, although the proofs cover only the identity and authority fragment. Zhao and Su (2024) and Maruthi and Singh (2025) prove threshold gates in isolation, and Mei et al. (2026) prove a static encryption predicate. Req 6 is graded Yes in 9 of the 25 studies: formal assurance is provided by only 4 of them, and the other 5 rest on empirical validation. An inverse

relation between predicate breadth and assurance strength was observed. Few studies execute adversarial scenarios that examine whether security controls can resist deliberate attempts to circumvent the authorisation process.

Table 2.9 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.9: Descriptions, issues and limitations of the studies on security assurance

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S8 Zhao and Su (2024)	A threshold traceable delegation scheme in which the patient delegates a threshold of l already-authorised users, who must jointly authorise an out-of-policy requester, with unforgeability argued under DBDH.	The authorisers are consumer-side delegates rather than patient-side stakeholders, the patient's own decision is unilateral, a trusted authority escrows keys, and there is no temporal, lifecycle, or purpose condition.	No	No	Yes	No	No	Yes
S11 Maruthi and Singh (2025)	Protection of IoMT data for unconscious patients, in which t-of-n patient-designated relatives release access through threshold proxy re-encryption, and the hospital and relatives are authenticated on chain.	Policy and temporal conditions are not evaluated, and the proofs cover the threshold gate in isolation rather than the complete decision.	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	An efficient dual-revocation CP-ABE scheme for IoMT that terminates access immediately through ciphertext update, motivated by consent withdrawal, with a security reduction under q-BDHE.	The proof covers a static encryption predicate, revocation operates at scheme level rather than on a consent object, and there is no multi-party approval.	No	No	No	Yes	Yes	Yes
S25 Wu and Zhang (2025)	HealthDID, a DID-based privacy-preserving EMR sharing system with three game-based definitions and three theorems proved by reduction, in which a zero-knowledge proof binds the authorisation to a specific requester.	The proofs cover only the identity and authority fragment, multi-party refers to the privacy requirements of several stakeholders rather than joint approval, and there are no policy, temporal, or lifecycle conditions.	Yes	Yes	No	No	No	Yes

2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily

establish that the requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient, or that the consent is still valid in time and lifecycle state at the moment of the request.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent, and the temporal validity and lifecycle state of the consent at the time of the request. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated Trust Computing framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent, and ensuring that the authorisation remains valid only within the time interval and lifecycle state of the consent. The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

Existing approaches solve single dimensions of trustworthy data sharing, each at a different layer of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. The systems that enforce purpose and time are authored by a single patient and lack a formal argument. The multi-party systems carry no purpose condition, whereas the proved schemes either omit policy, temporal validity, and lifecycle or, as in (Mei et al. 2026), prove only a static encryption predicate. Table 2.10 summarises the 25 studies against the six requirements, where Yes denotes that the requirement is fully satisfied and No that it is not fully

satisfied. Req 6 combines review questions 6 and 7, so in that column each study takes the higher of its formal assurance grade and its empirical validation grade.

Table 2.10: Comparison of the included studies against the key requirements

Study	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	No	No	No	No	No	No
S2 Albalwy et al. (2021)	Yes	No	No	Yes	No	Yes
S3 Al Amin et al. (2023)	Yes	No	No	No	No	No
S4 Ekholm et al. (2025)	No	Yes	Yes	No	No	No
S5 Eneh et al. (2026)	Yes	No	No	Yes	Yes	No
S6 Hagström et al. (2024)	No	Yes	No	No	Yes	Yes
S7 Jaiman and Urovi (2020)	Yes	No	No	Yes	No	Yes
S8 Zhao and Su (2024)	No	No	Yes	No	No	Yes
S9 Li et al. (2026a)	No	No	No	Yes	Yes	No
S10 Madine et al. (2020)	Yes	Yes	Yes	No	Yes	No
S11 Maruthi and Singh (2025)	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	No	No	No	Yes	Yes	Yes
S13 Panagoulias et al. (2026)	Yes	No	No	Yes	Yes	Yes
S14 Phuyal et al. (2026b)	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	No	No	No	No	No	No
S16 Punia et al. (2025)	No	No	Yes	Yes	Yes	No
S17 Román-Martínez et al. (2023)	Yes	No	No	Yes	No	No
S18 Hema et al. (2026)	Yes	No	No	Yes	Yes	No
S19 SooHoo et al. (2026)	No	No	No	No	No	No
S20 Tan et al. (2024)	Yes	Yes	Yes	No	No	No
S21 Tith et al. (2020)	Yes	No	No	Yes	No	No
S22 Tremper et al. (2026)	No	No	No	No	No	No
S23 Tseng et al. (2025)	No	Yes	No	No	No	No
S24 Wu et al. (2022)	No	No	No	No	No	No
S25 Wu and Zhang (2025)	Yes	Yes	No	No	No	Yes

The matrix supports four observations. First, counting only full satisfaction, Req 1 is met by 12 of the 25 studies, Req 2 by 7, Req 3 by 6, Req 4 by 10, Req 5 by 8, and Req 6 by 9. Second, no study satisfies all six, the maximum of four is reached by (Madine et al. 2020) and (Panagoulias et al. 2026), and five studies fully satisfy none. Third, Req 1 with Req 4 is the most frequent pair, in seven studies, whereas Req 2 and Req 4 never co-occur in full. Req 3 co-occurs with Req 4 only in (Punia et al. 2025), whose threshold lies outside the policy predicate and whose policy carries no purpose term. Similarly, Req 3 co-occurs with Req 6 only in (Maruthi & Singh 2025; Zhao & Su 2024). Fourth, the two quadruples are complementary, since Madine et al. (2020) lack full policy and assurance, whereas Panagoulias et al. (2026) lack multi-party approval and full identity depth.

The comparison shows that the contribution of this research is the explicit relationship it establishes among existing technologies, not their replacement. The consent object C carries the identity, authority, threshold, policy, temporal, and lifecycle conditions together, so that their relationship is verifiable. Section 2.5 positions the proposed framework relative to these requirements. The conjunction is formally specified and validated through allow-and-deny test cases and attack cases, whereas its formal

verification and the remaining lifecycle extensions of RQ5 are left for the next stage (Chapters 9 and 10).

The literature review identifies a consistent pattern of fragmentation across existing research. Across the corpus, Req 3 is the least satisfied requirement, while within Req 6, formal assurance alone is provided by 4 studies, argued informally by 9, and absent in 12. The other five Yes grades for Req 6 in Table 2.10 rest on empirical validation.

The review corrects one framing. Multi-party authorisation of patient consent is not absent from the literature, since the full-text coding shows it in six forms. These range from contingency-path joint approval and admission gates to delegated, witness, and custodial thresholds and guardian co-consent at registration, but no reviewed study treats it as a constitutive predicate that every access decision must satisfy together with the identity, policy, and temporal conditions. The gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision.

The review establishes two gaps. The first is a **conjunction gap**, since no study conjoins identity, authority, threshold, policy, temporal, and lifecycle conditions in one decision predicate in which multi-party approval is a standing condition and the patient defines the approving set. The second is an **assurance gap**, since co-existing conditions are neither proved nor tested as an authorisation decision, and any proof covers only a fragment of the predicate. As shown in Figure 2.2, the proposed research addresses both gaps by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object. Each of Req 1 to Req 6 also leaves a requirement-level gap, termed Gap 1 to Gap 6 and stated in Chapter 3, and each gap corresponds to the research question and objective of the same number in Chapter 3.

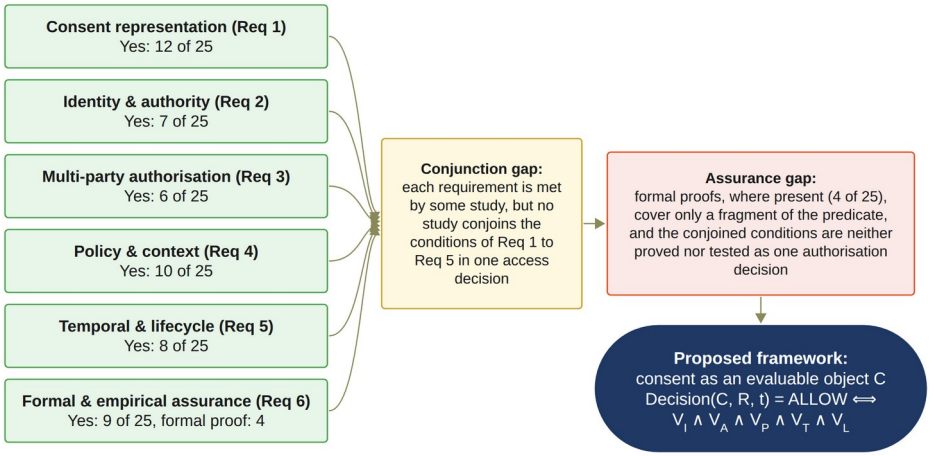


Figure 2.2: Synthesis of the review: the conjunction gap and the assurance gap addressed by the proposed framework, with the number of the 25 analysed studies graded Yes for each requirement in Table 2.10.

As presented in Tables 2.4 to 2.10, researchers have focused on securing individual aspects of healthcare data sharing: recording consent, verifying identity, approving access, and restricting the data that are released. However, from the perspective of the six requirements stated in Section 2.2, the existing work has the following drawbacks:

- *Inability to represent consent as an evaluable authorisation object (Req 1):* Existing consent approaches treat consent primarily as a record of a patient's permission (Akter & Sanam 2025; Prashanth et al. 2024), and some claim consent but leave it out of the access decision (Sawant & Gomes 2026). The evaluable consent objects reported since 2020 (Albalwy, Brass & Davies 2021; Eneh et al. 2026; Phuyal et al. 2026b; Shanmugham & Senthilkumar 2026; Tith et al. 2020) carry only a subset of

the identity, authority, threshold, policy, temporal and lifecycle conditions, and they are issued by a single party. Without such a representation, the existing literature does not allow an access request to be evaluated against the conditions that the patient actually set.

- *Inability to verify authority separately from identity (Req 2):* A valid decentralised identity establishes who a participant is (Mazzocca et al. 2025), but it does not establish what that participant is authorised to do. Authority is verified separately from authentication in only 10 of the 25 studies, and Req 2 is graded Yes in 7 of them (Table 2.10). Without this separation, an authenticated participant is treated as an authorised one.
- *Absence of multi-party approval as a standing condition of every access decision (Req 3):* Multi-party approval appears in the reviewed studies as a contingency path, an admission gate or a registration-time co-consent (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). The approving set is defined on the institutional or delegate side (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024), or it is appointed by the patient but evaluated only as a contingency path or as a key-custody threshold (Maruthi & Singh 2025; Tan, Chi & Lam 2024). Req 3 is the least satisfied requirement, graded Yes in 6 studies (Table 2.10). None of the papers examined makes approval by a patient-defined set a condition of every access decision.
- *Inability to bind purpose and data scope to the same decision as identity, authority and approval (Req 4):* Purpose and data-scope constraints are enforced by 10 of the 25 studies (Table 2.10), but in none of them are they bound to the same decision as identity, authority and multi-party approval; in the reviewed studies, multi-party approval is never conjoined with a purpose condition (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). Without this binding, a valid identity and sufficient approvals can be used to obtain data outside the authorised scope.
- *Absence of temporal and lifecycle evaluation at the time of each access request (Req 5):* Req 5 is graded Yes in 8 of the 25 studies (Table 2.10). In these studies, the validity period, the lifecycle state and the revocation of a consent are enforced on a credential or at registration rather than evaluated when the request is made. Without such evaluation, a consent that has expired or been revoked remains usable once its approvals have been recorded.
- *Absence of formal and empirical assurance of the complete decision (Req 6):* Within Req 6, formal assurance is provided by 4 studies, argued informally by 9, and absent in the rest (Section 2.4.6). The studies that coordinate several mechanisms in one decision (Ferreira et al. 2025; Panagoulias et al. 2026; Phuyal et al. 2026b; Punia et al. 2025; Shanmugham & Senthilkumar 2026) test their own decisions, but none of them proves or tests a conjunction that includes multi-party approval, and any proof covers only a fragment of the predicate. Without such assurance, the correctness of the decision as a whole rests on the correctness of its parts.

The review has limitations. A single search string and a single round of coding mean that a small number of relevant studies may have been missed.

In the next section, we present our proposed framework to address the gaps.

2.5 Trust-Oriented Multi-Party Consent Authorisation Framework

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as

enabling technologies supporting the broader trust model. Sections 2.5.1 to 2.5.6 state how the proposed framework, implemented in the HALAH prototype, addresses each requirement and the research objective that delivers it.

2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)

Consent is represented as the evaluable object C = (I, A, P, T, L, E), created through Algorithm 1 and evaluated at every access request. This requirement is delivered by RO1, presented in Chapter 5.

2.5.2 Decentralised Verification of Identity and Authority (Req 2)

DID and VC verification separates identity from authority and is evaluated as VI through Algorithm 2. The prototype checks the DID format, verifies each guardian's credential before the signature is added, and verifies the requesting doctor's credential at every access request. Full DID resolution is planned for the next stage. This requirement is delivered by RO2, presented in Chapter 6.

2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)

N-of-N approval by the guardian set G with EIP-712 guardian signatures (Bloemen, Logvinov & Evans 2017), evaluated as VA through Algorithm 3. This requirement is delivered by RO3, presented in Chapter 7.

2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4)

Purpose and a non-empty data scope within the consent are evaluated as VP through Algorithm 4. This requirement is delivered by RO4, presented in Chapter 8.

2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)

The validity window VT, revocation, the lifecycle states, and the on-chain revocation on Sepolia are implemented, as specified in Algorithm 5. The SUSPENDED state and the lifecycle transition check are not yet implemented. This requirement is delivered by RO5, presented in Chapter 9.

2.5.6 Verifiable Auditability and Security Assurance (Req 6)

Audit ledger evidence and 46 automated tests, including twelve attack scenarios A1 to A12. The testing part of Algorithm 6 is done. Formal analysis is left for the next stage. This requirement is delivered by RO6, presented in Chapter 10.

2.6 Conclusion

This chapter reviewed the literature on multi-party consent and trustworthy data sharing in healthcare. Six requirements were stated for a trustworthy multi-party consent authorisation: an evaluable consent object, decentralised verification of identity and authority, multi-party authorisation through a verifiable threshold, policy- and context-aware enforcement at the time of access, temporal validity and lifecycle control, and verifiable auditability and security assurance. The literature was searched in seven databases, screened under the PRISMA 2020 statement, and evaluated against six quality questions, and 25 primary studies were analysed in full against the requirements.

The review shows that each requirement is met by some of the studies, but that no study meets them together. Multi-party approval, where it appears, is a contingency path, an admission gate or a registration-time co-consent, not a standing condition of every access decision with an approving set defined by the patient. Purpose and data scope are rarely

bound to the same decision as identity, authority and approval, and temporal validity and revocation are usually enforced on a credential rather than at the time of each request. Where several conditions are combined, the combined decision is neither proved nor systematically tested. These findings form the conjunction gap and the assurance gap. The next chapter states these gaps, the research questions that follow from them, and the objectives of this thesis.

CHAPTER 3

RESEARCH QUESTIONS AND OBJECTIVES

3.1 Introduction

Chapter 2 reviewed the literature on multi-party consent and trustworthy data sharing in healthcare and found that the conditions for a trustworthy access decision exist in the literature but are never joined in one decision that is evaluated at every request, and that where they are joined the decision is neither proved nor tested. This chapter turns that finding into the research problem of the thesis. Section 3.2 states the research gap, first as a whole and then as six requirement-level gaps. Section 3.3 defines the terms used in the rest of the thesis: the patient, the guardian set, the threshold, the requester and the consent object. Section 3.4 states the main research question and the six sub-research questions, and shows that they form one integrated problem rather than six separate ones. Section 3.5 states the six research objectives and the relationship between each objective and its question. Section 3.6 concludes the chapter.

3.2 Gaps in the Literature

From a thorough review of the existing literature documented in Chapter 2, we have identified the following six gaps:

1. There is no existing representation of patient consent that carries the identity, authority, threshold, policy, temporal and lifecycle conditions of access as one evaluable object. Consent is recorded as a permission, and the evaluable objects that exist carry only a subset of the conditions and are issued by a single party.
2. There is no method that verifies the authority of a participant separately from the authentication of that participant within the same access decision, so a valid identity is taken as permission.
3. There is no mechanism by which multi-party approval, with the approving set defined by the patient, is a standing condition of every access decision rather than a contingency path, an admission gate or a registration-time co-consent.
4. There is no enforcement that binds the purpose and the data scope of a request to the same decision as identity, authority and collective approval.
5. There is no evaluation of temporal validity, lifecycle state and revocation at the moment of each access request; where they exist, they are enforced on a credential or at registration.
6. There is no formal definition or systematic testing of the complete authorisation decision under valid, invalid and adversarial conditions; any proof covers only a fragment of it.

3.3 Key Definitions

The patient, as the data subject, may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. The guardian set G is the set of designated participants whose independent approval is required. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties. In the current prototype, the members of G are guardians. Each member of G is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. The threshold N is the number of valid approvals from members of G needed for activation. If the number of valid approvals is below the required threshold N, the consent cannot produce an effective authorisation decision. The authorised doctor D is the requester whose access request R is evaluated against the consent object C.

The consent object against which these questions are evaluated is defined in Equation (3.1), where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence. Within A, the guardian set G and the threshold N define the required approvals. T is the temporal validity window, and L represents the current state of the consent object and its permissible transitions, including whether the consent remains active or has been revoked. This formulation changes the role of consent from a passive record into an evaluable authorisation object.

$$C = (I, A, P, T, L, E) \tag{3.1}$$

3.4 Research Questions

From the systematic literature review documented in Chapter 2, and the shortcomings outlined in Section 2.4.7, it is clear that there are several gaps in the existing literature on trustworthy multi-party consent authorisation for healthcare data sharing.

Based on the identified research gap, the overarching research question is formulated as follows: **"How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?"** The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework. For brevity, SRQ1 to SRQ6 are referred to as RQ1 to RQ6 throughout this thesis.

- **SRQ1 (Trust-Centric Consent Modelling):** How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?
- **SRQ2 (Decentralised Identity and Authority Trust):** How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?
- **SRQ3 (Trustworthy Multi-Party Authorisation):** How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?

- **SRQ4 (Policy- and Context-Aware Access Control):** How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?
- **SRQ5 (Temporal and Lifecycle Trust):** How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?
- **SRQ6 (Formal Security Assurance and Empirical Validation):** How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

3.4.1 Research Questions as an Integrated Problem

The six sub-research questions are not independent technical questions. RQ1 establishes the conceptual object. RQ2 establishes the trustworthiness of the participants. RQ3 then extends this participant-level trust into a collective decision. RQ4 determines whether the resulting authorisation is applicable to the specific data-access request. RQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, RQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly. The integrated authorisation condition can therefore be expressed as Equation (3.2). Here, V_I represents identity and authority validity, V_A collective authorisation validity, V_P policy and contextual compliance, V_T temporal validity, and V_L consent lifecycle validity.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{3.2}$$

A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial. In the prototype, an ALLOW decision additionally requires the exploratory jurisdiction check V_J (Chapter 8) to pass and the Groth16 ZK proof (Groth 2016) to verify, so a request that satisfies the five predicates is still denied when either fails, as in Scenario 4 (Chapter 10) and attack A9 (Chapter 10). Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Thus, RQ6 operates as an assurance layer over the mechanisms established by RQ1–RQ5.

3.5 Research Objectives

The research objectives turn the research gap into concrete research and development activities. The complete research programme consists of six research objectives, corresponding to six research questions.

3.5.1 RO1: Trust-Centric Consent Model

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model incorporates identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made. RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. It defines the information that must be

represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

3.5.2 RO2: Decentralised Identity and Authority Trust

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data.

3.5.3 RO3: Trustworthy Multi-Party Authorisation

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision. The objective is to prevent unilateral authorisation where collective approval is required. The guardian set G, fixed at consent creation, defines which participants are eligible to contribute an approval to the authorisation process. Each participant must submit an approval that can be independently verified through EIP-712 signature recovery. Invalid approvals are rejected and must not contribute to the threshold count. In the current prototype, a valid signature is required from every listed guardian, so the threshold equals |G|, an N-of-N condition demonstrated in the 2-of-2 configuration. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold. RO3 addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

3.5.4 RO4: Policy- and Context-Aware Access Control

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is a non-empty subset of the authorised EMR modules. In the current prototype, the request purpose is taken from the consent, so the purpose check confirms that the consent purpose is a supported healthcare use, while the comparison with a separately declared request purpose is left to the next stage. RO4 directly addresses RQ4 and completes the foundational authorisation model. Together, RO1–RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

3.5.5 RO5: Temporal and Lifecycle Trust

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. RO5 addresses RQ5 and extends the foundational authorisation model into a dynamic consent environment. The current HALAH code already collects a start time and expiry time during consent creation. The prototype records them on-chain as notBefore and expiry within the consent token, enforces the temporal validity window at every access decision through V_T, implements end-to-end revocation, including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. Access can be granted only in the ACTIVE state, and V_L checks this state at every access decision. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied. The remaining work concerns the

SUSPENDED state, the lifecycle transition check, a formal lifecycle model, and hardening these controls and extending them to consent modification, delegation, and guardian-set changes.

3.5.6 RO6: Formal Security Assurance and Empirical Validation

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios. RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The prototype must execute valid consent workflows, and it must also behave correctly when one or more trust conditions are violated. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype. In particular, 46 automated tests cover signature rejection, proof tampering, credential checks, and twelve attack scenarios, A1 to A12, against the components of C and the contract. All twelve attacks are refused. Preliminary measurements of on-chain cost, confirmation latency, and processing time have been obtained, and a live out-of-jurisdiction request against a consent anchored on the deployed Sepolia contract was refused by the exploratory jurisdiction check of the application (Chapter 8). The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. Although preliminary implementation and scenario-based testing support the current stage findings, the complete formal analysis, through proofs or model checking, and a larger evaluation under load will be conducted as part of next stage works.

3.5.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives, with the status of each objective, is summarised in Table 3.1. The mapping follows the structure of the research programme and maintains a direct correspondence between each research question and its associated objective. RO1 to RO6 are realised in Chapter 5 to Chapter 10 respectively, each in the section presenting the solution for the corresponding research question. Because each research question corresponds to one gap identified in Chapter 2, each objective addresses the gap of the same number, so that RO1 addresses Gap 1 and RO6 addresses Gap 6. Each research question therefore has one research activity, and each objective contributes to the framework. RO1 to RO4 are delivered in this stage, together with their validation and evaluation through the implemented prototype, whereas, as stated in Chapter 1, RO5 is in progress and RO6 is partially completed. Their remaining work is detailed in Chapter 9 and Chapter 10, and its schedule is presented in Chapter 11. The distinction between current stage and next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives.

Table 3.1: Research questions, research objectives, and the status of each objective

RQ	Research objective	Description	Status
RQ1	RO1: Trust-Centric Consent Model	To develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object.	Done
RQ2	RO2: Decentralised Identity and Authority Trust	To develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials.	Done
RQ3	RO3: Trustworthy Multi-Party Authorisation	To develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision.	Done
RQ4	RO4: Policy- and Context-Aware Access Control	To develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.	Done
RQ5	RO5: Temporal and Lifecycle Trust	To extend the trust-oriented framework with temporal validity and consent lifecycle controls.	In Progress
RQ6	RO6: Formal Security Assurance and Empirical Validation	To formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.	Partially completed

3.6 Conclusion

This chapter stated the research problem. The gap found in Chapter 2 is the absence of an integrated model in which identity, authority, multi-party approval, policy, temporal validity and lifecycle state are evaluated together at every access request, with an approving set defined by the patient, and in which that joint decision is formally and empirically assured. The first five requirement-level gaps form the conjunction gap and the sixth forms the assurance gap.

From this gap, one main research question was stated: how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority and policy constraints. The question was divided into six sub-research questions, one per gap, and each sub-research question was matched with one research objective. The six questions are not independent: the first defines the consent object, the second and third establish who may take part and how they decide together, the fourth and fifth decide whether a particular request is allowed now, and the sixth assures the whole. The next chapter presents the research methodology and an overview of the solution proposed for each question.

CHAPTER 4

RESEARCH METHODOLOGY AND SOLUTION OVERVIEW

4.1 Introduction

Chapter 3 stated the research gap, the main research question, the six sub-research questions and the six research objectives. This chapter explains how the research was carried out and gives an overview of the solution before the detailed chapters. Section 4.2 defines the terms that the solution uses and that Chapter 3 did not define. Section 4.3 presents the selected research methodology, Design Science Research, and shows what each of its stages produced in this thesis. Section 4.4 gives an overview of the solution as one end-to-end workflow, from the creation of a consent to the recording of an access decision. Sections 4.5 to 4.10 give an overview of the solution for each research question, RQ1 to RQ6, and name the chapter in which each solution is presented in full. Section 4.11 concludes the chapter.

4.2 Key Definitions

The following terms are used in the overview of the solution and in the chapters that follow. The patient, the guardian set G, the threshold N, the authorised doctor D, the access request R and the consent object C were defined in Chapter 3.

Trust predicate. A condition that must hold before access is allowed, evaluated as true or false at the time of the request. The framework has five: VI for identity and authority, VA for collective authorisation, VP for policy and context, VT for temporal validity and VL for the lifecycle state.

Decision function. The rule Decision(C, R, t) that returns ALLOW only when all five trust predicates hold for the consent C, the request R and the time t, and DENY otherwise. It was stated as Equation (3.2).

Approval. A signed statement by one guardian that approves one consent. An approval is valid only when it is signed by a member of G who has not already approved the same consent.

Verified approving set Av. The subset of G whose approvals have been verified. The consent becomes active when |Av| reaches N.

Lifecycle state. The state of a consent at a point in time: pending until the guardians have approved, not started before its start time, active while it can release data, and expired or revoked when it no longer can.

Audit event. A record written to the audit ledger for every action on a consent, including its creation, each approval, each access decision with the result of the five predicates, and its revocation.

Scenario. One complete run of the prototype that exercises a defined path, such as the creation and approval of a consent followed by an allowed request, or a request made after revocation.

Attack scenario. A deliberate attempt to obtain access while one of the trust conditions is not satisfied, such as an approval from a signer outside G or a request outside the authorised data scope. The framework must refuse every attack scenario.

Prototype. The HALAH implementation of the framework, used to show that the design can be built and to evaluate it against the scenarios and attack scenarios.

4.3 Selected Research Methodology

This research follows the Design Science Research (DSR) methodology, based on the process model of Peffers et al. (2007), as shown in Figure 4.1. DSR fits this research because its aim is to design and evaluate an artefact, the trust-oriented authorisation framework and its HALAH prototype, that addresses an identified problem. The process has five stages. Knowledge gained in each stage feeds back into the process through iteration, so that the design is refined over successive cycles.

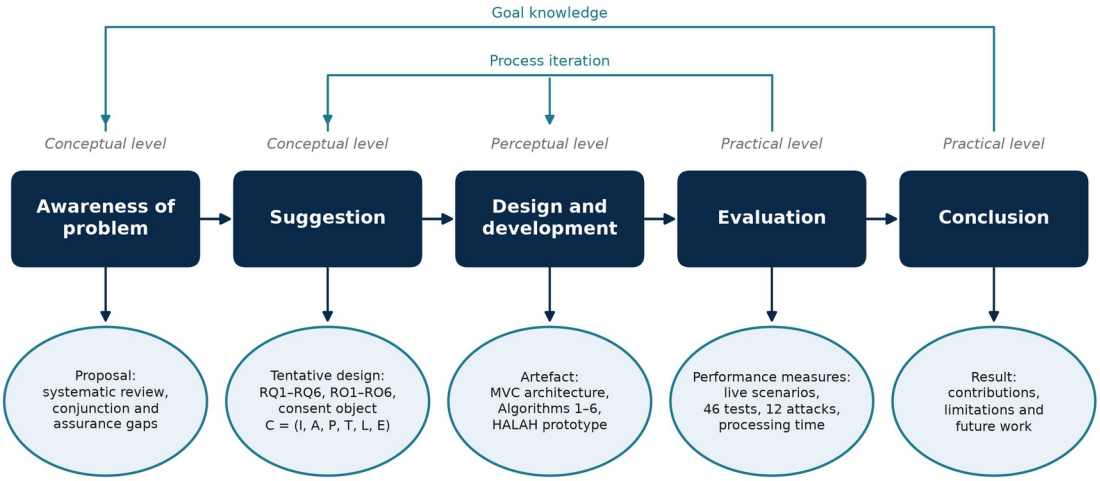


Figure 4.1: The Design Science Research process of this thesis, with the output of each stage, adapted from Peffers et al. (2007).

In the awareness-of-problem stage, the systematic literature review of Chapter 2 identified the fragmentation of trust conditions in existing consent mechanisms, and its output is the research proposal. In the suggestion stage, the research gap was turned into the research questions RQ1 to RQ6, the research objectives RO1 to RO6, and the integrated trust model, which together form the tentative design. In the design and development stage, the consent object C, the MVC architecture, and Algorithms 1 to 6 were designed, and the HALAH artefact was implemented on the Sepolia testnet (Chapters 5 to 10). In the evaluation stage, the artefact was evaluated through access scenarios, 46 automated tests including twelve attack scenarios, and measurements of gas and processing time, which provide the performance measures (Chapter 10). In the conclusion stage, the results, the contributions, and the remaining lifecycle and assurance work are reported.

4.4 Solution Overview

The framework is best understood as one workflow that starts when a patient creates a consent and ends when an access decision is recorded. This section presents that

workflow and the two conditions that govern the collective authorisation step. The architecture that carries the workflow is presented in Chapter 5.

Figure 4.2 presents the end-to-end workflow of the proposed framework. The workflow begins when the patient creates a consent request. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorise and provides the policy context against which subsequent access requests can be evaluated. The next step of the workflow applies a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The framework separates identity authentication from authorisation. A successfully verified DID or VC does not, by itself, grant permission to access patient data. The framework then collects the participants' independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let A_v denote the set of participants whose approvals have been verified and let N denote the required authorisation threshold, as in Equation (4.1). Here, Token(C) $\neq \emptyset$ means that C has been assigned a token identifier, and Revoked(C) $= 0$ means that the consent has not been revoked.

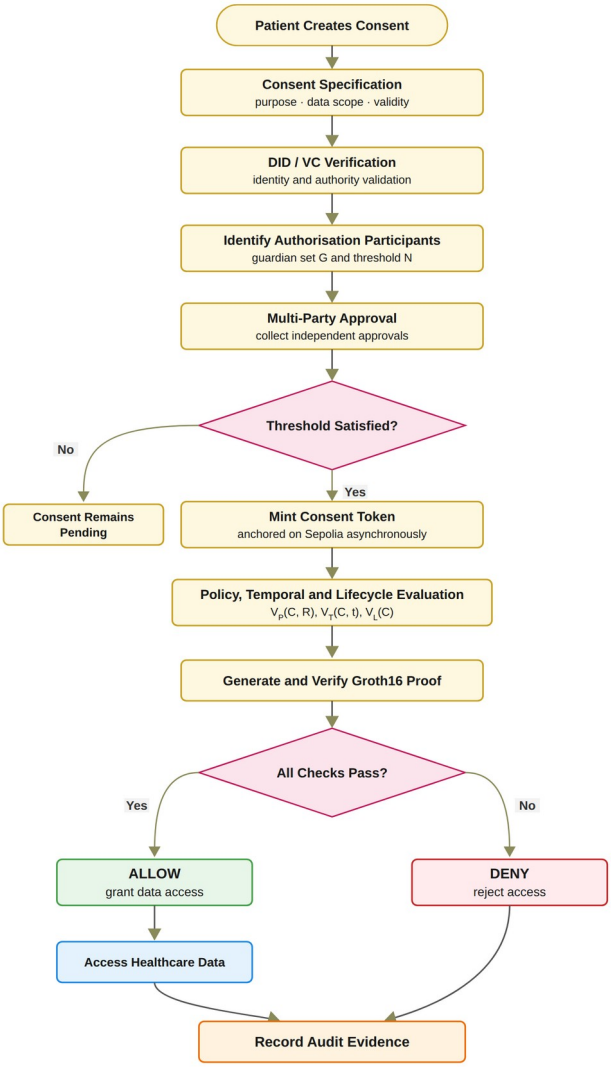


Figure 4.2: End-to-end workflow of the trust-oriented consent authorisation framework.

$$V_A(C) = 1 \text{ if } |A_v| \geq N \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0, \text{ and } 0 \text{ otherwise.} \quad (4.1)$$

Only independently verified participants can contribute to the set of verified approving participants A_v, as defined in Equation (4.2), where A_s denotes the set of approvals submitted for C. A_v therefore contains each member of G at most once, and an approval from a signer outside G does not enter A_v. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. This distinguishes the framework from reviewed systems in which joint approval is a contingency path, a witness or notary threshold, a registration-time co-consent, a documentation-time gate on guardian access, an institution-side admission gate, a custodial M-of-N signature, a key-share reconstruction, or a threshold proxy re-encryption.

$$A_v = \{g \in G \mid \exists\, a_i \in A_s \text{ submitted by } g \text{ with } V_I(g) = 1\}. \tag{4.2}$$

In the implemented prototype, the threshold is fixed at $N = |G|$, as justified in Chapter 7, and once the N-of-N condition is satisfied, the consent token is minted in the local ledger and a background job anchors the mint on Sepolia asynchronously. The policy, temporal and lifecycle checks V_P, V_T and V_L, together with the exploratory jurisdiction check V_J, are then evaluated, a Groth16 proof is generated and verified before access is granted, and the audit evidence is recorded. Beyond the access decision shown in Figure 4.2, the prototype continues through patient-initiated revocation and the corresponding on-chain revoke transaction, after which the auditor reviews the record and the verification tool performs an independent verification. If the required threshold is not satisfied, the consent remains pending, and any access request made against it is denied. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses a limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent authorises access to observations and medications, a request for observations, medications, and procedures should be rejected because the request exceeds the authorised data scope. Similarly, the purpose must be a supported healthcare use. The full design also requires the requested purpose to match the purpose recorded in the consent, which the prototype does not yet compare, as Chapter 8 explains. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. Both successful and denied decisions should be recorded because a trustworthy authorisation framework requires accountability not only for data that were released but also for access attempts that were rejected. In the prototype, every denial, including one against a consent that is not ACTIVE, is recorded with its complete decision matrix.

4.5 Overview of Solution for RQ1

RQ1 asks how patient consent can be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints and authorisation evidence. The solution is the trust-centric consent model of RO1, in which consent is no longer a stored record of permission but the object $C = (I, A, P, T, L, E)$ that every access request is evaluated against. I carries the identity of the patient, the doctor and the guardians; A carries the authority requirements, the guardian set G and the threshold N; P carries the purpose and the data scope; T the validity window; L the lifecycle state; and E the evidence of every decision taken on the consent.

The consent object is created through Algorithm 1. The patient selects the doctor, names the guardians, chooses the data modules, states the purpose and sets the start and expiry dates. The system validates each field, assigns a unique consent identifier, sets the state to PENDING_SIGNATURE, sets N to the number of guardians, persists the object and records the creation event in the audit ledger. From that point the consent can be

evaluated, not merely looked up. The model, the algorithm and its realisation in the HALAH prototype are presented in Chapter 5, together with the research architecture that carries it.

4.6 Overview of Solution for RQ2

RQ2 asks how decentralised identities and verifiable credentials can establish trustworthy participants while separating identity authentication from authorisation authority. The solution is the identity and authority verification mechanism of RO2. Every participant holds a decentralised identifier, and every participant who takes part in a decision holds a verifiable credential issued by a trusted issuer that states their role. When a guardian approves or a doctor requests data, the framework checks the identifier and then the credential: the signature must verify, the issuer must be in the registry of trusted issuers, the subject of the credential must be the identifier presented, the current time must lie inside the validity period, and the role must be the one the step requires. A doctor must also be the doctor named in the consent.

The result is the predicate VI. A valid identity with no credential, or with a credential of the wrong role, fails VI and is refused before any other check. This is what separates who the participant is from what the participant may do. The verification model, Algorithm 2 and its realisation are presented in Chapter 6.

4.7 Overview of Solution for RQ3

RQ3 asks how multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to authorise access on their own. The solution is the multi-party authorisation mechanism of RO3. The patient fixes the guardian set G and the threshold N when the consent is created. Each guardian signs an approval over the consent identifier and their own identifier, so an approval cannot be moved to another consent. Only approvals from distinct members of G whose credentials verify enter the verified approving set Av; an approval from a signer outside G, or a second approval from the same guardian, does not advance the count.

The consent stays pending, and releases no data, until |Av| reaches N. In the prototype every listed guardian must approve, so N equals |G|. Once the threshold is reached the consent becomes active and a token is recorded as evidence, and the approvals are checked again, as VA, at every later request. The mechanism, Algorithm 3 and its realisation are presented in Chapter 7.

4.8 Overview of Solution for RQ4

RQ4 asks how policy, purpose and data-scope constraints can be incorporated into the authorisation decision so that valid identities and sufficient approvals cannot be used to obtain data outside what the patient allowed. The solution is the policy- and context-aware access control of RO4. The consent carries the purpose and the set of data modules the patient authorised. When a doctor requests data, the predicate VP checks that the purpose is a supported healthcare use and that the requested modules form a non-empty subset of the authorised modules. A request for observations, medications and procedures against a consent that allows observations and medications is refused, although the requester is the right doctor and the guardians have approved.

VP is therefore the condition that makes identity and approval necessary but not sufficient. The policy model, Algorithm 4 and its realisation are presented in Chapter 8.

4.9 Overview of Solution for RQ5

RQ5 asks how temporal validity and lifecycle controls can ensure that an authorisation remains valid only within its permitted time interval and lifecycle state. The solution is the temporal and lifecycle trust of RO5. The consent carries a start time and an expiry time, and the predicate VT checks at every request that the request time lies between them. The consent also has an explicit lifecycle: it is pending until the guardians have approved, active while it can release data, and expired or revoked afterwards. The patient can revoke an active consent at any time. The predicate VL checks at every request that the state is active, so a consent that has expired or been revoked cannot be used, whatever approvals it once held.

Because VT and VL are evaluated at the time of each request rather than once at registration, a change in the consent takes effect on the next request. The lifecycle model, Algorithm 5 and its realisation are presented in Chapter 9.

4.10 Overview of Solution for RQ6

RQ6 asks how the security properties of the authorisation mechanism can be formally defined and empirically evaluated to show that the implemented framework enforces authorised and unauthorised decisions correctly. The solution of RO6 has two parts that complement each other. The formal part defines the security properties of the integrated decision, authorisation integrity, threshold authorisation security and lifecycle safety, and states the assumptions under which they are analysed. The empirical part evaluates the HALAH prototype through scenarios in which the expected and the observed decisions are compared, and through attack scenarios in which each trust condition is deliberately bypassed. Algorithm 6 defines this validation procedure, and Chapter 10 presents the formal properties, the prototype, the scenarios, the measured results and the attack scenarios.

4.10.1 Testing and Verification of the Solution

The prototype is tested at three levels. Live scenarios run the whole workflow through the web interface: a consent is created, each guardian approves, the authorised doctor is allowed, a request that does not satisfy the conditions of the consent is refused, and a request after revocation is refused. Automated tests, 46 in all, check each predicate on its own and together, including twelve attack scenarios, A1 to A12, in which a signer outside G, a replayed signature, a duplicate approval, an over-scope or empty request, a request outside the validity window, a request after revocation, a tampered proof and a forged credential are each refused. The processing time of each check is measured so that the cost of the decision is known. Every decision, allowed or refused, is written to the audit ledger with the result of the five predicates, and the ledger is the evidence used in Chapter 10.

4.11 Conclusion

This chapter presented the research methodology and an overview of the solution. The research follows Design Science Research: the systematic review produced the proposal, the research questions and objectives and the consent model formed the tentative design, the architecture, the algorithms and the HALAH prototype are the artefact, the scenarios, tests, attack scenarios and measured times are the performance measures, and the contributions and remaining work are the result. The solution was then shown as one workflow, from the creation of a consent to the recording of an access decision, and summarised for each research question: an evaluable consent object for RQ1, identity and authority verification for RQ2, multi-party authorisation for RQ3, policy and scope enforcement for RQ4, temporal and lifecycle control for RQ5, and formal and empirical

assurance for RQ6. The next chapter presents the research architecture and the trust-centric consent model in full.